

통 보

- 제 목 : 공단 이메일 보안관리에 관한 사항
- 관계기관 : ■■■■■병원
- 내 용
가. 업무개요

우리 공단은 클라우드(SaaS)¹⁾ 기반 이메일 시스템을 [표]와 같이 2023년 4월부터 운영하고 있으며, 본사 및 ■■■■■병원은 망분리 환경에서 이메일을 사용하고 있는 반면, 지방병원 등 소속기구는 망분리가 적용되지 않아 일반 인터넷 망 기반에서 이메일을 이용할 수 있는 환경에 있습니다.

[표] 공단 이메일 시스템 운영 현황

추진방법	운영 시작일	로그인 변경 내용	계약업체	인프라 기반	비고
민간클라우드 (SaaS) 이용계약	2023.4.28.	구글OTP 기반 이중 인증 적용	□□□□□	KT G-Cloud 이용	외부에서도 인증 후 접속 가능

(자료: ■■■■■병원 기획조정실 제공자료 재구성)

나. 관계법령 및 판단기준

공단 이메일 시스템은 인터넷망에서 메일 ID/PW와 OTP(일회용 인증코드)를 통한 본인 인증 후 접근하도록 설계되어 있으며, 지방병원 등 소속기구는 그룹웨어 로그인 후 신규 메일 알림 아이콘 클릭을 통해 이메일 서비스(SaaS)에 연동되는 방식으로 이용하고 있습니다.

공단 「정보보안업무 처리지침」 제24조(사용자계정 관리)에서는 시스템 관리자가 사용자에게 계정을 부여·관리함에 있어 비인가자 도용 및 불법 접속을 방지하도록 규정하고 있으며, 특히 비밀번호 등 사용자 식별 및 인증수단이 없는 사용자계정 사용을 금지하고, 비인가자의 침입 여부를 점검하도록 정하고 있습니다.

1) 클라우드(SaaS) : 공단 내부 서버가 아니라 인터넷 기반의 외부 서비스 업체 서버에서 운영하는 방식

한편, 공단 내부 업무망 계정과 외부 클라우드 기반 시스템을 연동하여 자동 로그인 방식으로 사용할 경우에는, 접근통제(허가된 사용자만 접근하도록 제한), 인증토큰 관리(인증값을 일정 시간 후 자동 폐기), 세션 만료 설정(일정 시간 미사용 시 자동 로그아웃), URL 직접접근 제한 등 기술적·관리적 안전조치를 적절하게 유지하여야 하며, 특히 발급되는 접속 URL 또는 세션 토큰이 일정 시간 경과 시 자동으로 만료되어 재사용되지 않도록 관리해야 합니다.

다. 감사결과 확인된 문제점

그런데 이메일 접근 방식을 확인한 결과, 그룹웨어 로그인 후 이메일함으로 연결되는 SaaS 메일 접속 URL이 고정된 형태로 제공되고 있었으며, 해당 URL을 복사하여 저장하면 그룹웨어 로그인(SSO) 및 별도의 OTP 인증 없이도 이메일함에 직접 접근할 수 있는 상황임을 확인하였습니다.

또한, 해당 URL은 3개월이 경과한 후에도 별도 인증 없이 동일하게 이메일함에 접근할 수 있었으며, 이 URL을 통해 본인 및 타인 이메일함에 언제든지 비인가 접근이 가능한 상태였음을 확인하였습니다.

4. 관계기관 의견

■■■㉠㉠병원에서는 감사결과를 수용하여 별다른 의견을 제시하지 않았습니다.

5. 조치할 사항

○ ■■■㉠㉠병원장은

- 공단 이메일 시스템에서 별도의 인증이나 로그인 절차 없이 이메일함에 접근되지 않도록 보안 조치를 강화하여 주시기 바랍니다. (통보)